

LEGAL OPINION

Data Processing Arrangements and GDPR Liability Exposure

Ref: VA/OPN/2024/0031 | Date: 20 February 2024 | PRIVILEGED & CONFIDENTIAL

CLIENT: HealthBridge Analytics BV

MATTER: Assessment of data processing liability under the GDPR in connection with proposed SaaS platform deployment

PREPARED BY: Dr. Isabelle Fontaine, Senior Associate; reviewed by Prof. Jan van Dijk, Partner

1. SCOPE AND BASIS OF OPINION

- 1.1 We have been asked to advise HealthBridge Analytics BV (“**HealthBridge**”) on the allocation of data controller and data processor responsibilities, and the associated GDPR liability exposure, arising from the proposed deployment of its SaaS analytics platform to three hospital networks in the Netherlands and Belgium.
- 1.2 This opinion is based on: (i) the draft Data Processing Agreement (“**DPA**”) provided to us on 5 February 2024; (ii) the proposed Technical and Organisational Measures (“**TOMs**”) schedule; and (iii) the applicable provisions of Regulation (EU) 2016/679 (“**GDPR**”) and the Dutch Implementation Act (*Uitvoeringswet AVG*).
- 1.3 This opinion is strictly limited to the questions identified in Section 2 and does not address any matters of Belgian law.

2. QUESTIONS ADDRESSED

- 2.1 Whether HealthBridge operates as a data processor, data controller, or joint controller in respect of the personal data processed through its platform.
- 2.2 The scope of HealthBridge's liability exposure under Article 82 GDPR in the event of a personal data breach.
- 2.3 Whether the indemnification provisions in the draft DPA are adequate to protect HealthBridge from third-party claims.

3. ANALYSIS

- 3.1 **Controller/Processor Classification.** On the basis of the information provided, it is our opinion that HealthBridge operates as a **data processor** in respect of patient data processed on behalf of the hospital networks (who act as data controllers). HealthBridge determines the technical means of processing but not the purposes, which remain with the hospital networks.
- 3.2 **Joint Controller Risk.** HealthBridge's use of aggregated patient datasets for model training creates a meaningful risk of classification as a **joint controller** for that processing activity. We recommend

HealthBridge either: (a) obtain explicit consent from the hospitals for model training use; or (b) anonymise training datasets to a standard compliant with Recital 26 GDPR.

3.3 Article 82 Liability. Under Article 82(2) GDPR, a data processor is liable for damage caused by processing only where it has not complied with GDPR obligations or acted outside the controller's lawful instructions. Given the volume of special category health data (Article 9 GDPR), a breach could attract fines of up to EUR 20 million or 4% of global turnover under Article 83(5) GDPR, and civil liability claims.

3.4 Indemnification Assessment. Clause 14.2 of the draft DPA limits HealthBridge's indemnification exposure to direct damages not exceeding the fees paid in the preceding twelve-month period. This cap is commercially reasonable but may be challenged as insufficient given the sensitivity of the data. We recommend HealthBridge maintain a minimum cyber liability insurance policy of EUR 5,000,000 per incident.

4. CONCLUSIONS AND RECOMMENDATIONS

- 4.1 HealthBridge is properly characterised as a data processor for primary processing activities. The joint controller risk for model training should be mitigated as described in paragraph 3.2 above.
- 4.2 HealthBridge's GDPR liability exposure is material. The indemnification cap in the DPA is reasonable but should be supplemented by adequate insurance coverage.
- 4.3 We recommend the following amendments to the draft DPA:
- (a) Insert an explicit prohibition on processing data beyond the documented purpose (Clause 5);
 - (b) Strengthen the sub-processor notification obligation from 30 to 14 days (Clause 8);
 - (c) Include a data breach notification SLA of 24 hours to align with evolving supervisory expectations (Clause 11); and
 - (d) Add a model training restriction clause confirming pseudonymisation or anonymisation requirements.
- 4.4 **This opinion is governed by Dutch law and is issued solely for the benefit of HealthBridge Analytics BV. It may not be relied upon by any third party without our prior written consent.**

Vandermeer & Associates NV

Herengracht 182, 1016 BR Amsterdam
20 February 2024